

W12D4 - Scansione finale

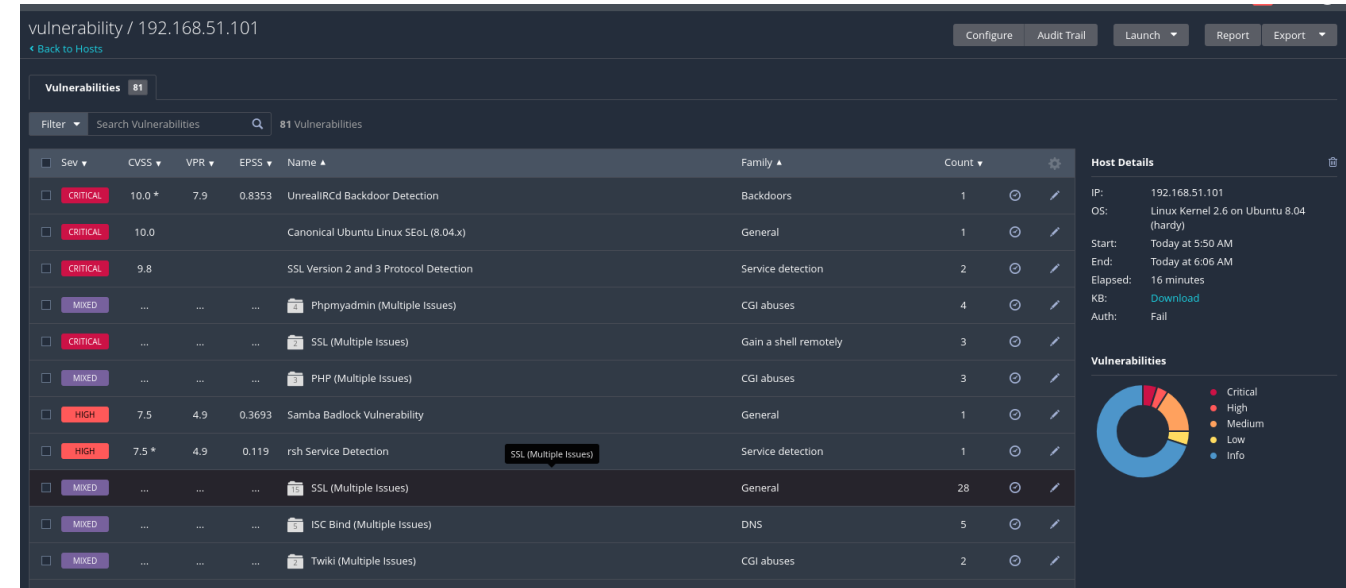
Studente: Riccardo Luzzi
 Corso: Cyber Security
 Sistema utilizzato: Kali Linux
 Strumento di verifica: Nessus Essentials - Basic Network Scan
 Target: Metasploitable - 192.168.51.101

1. Verifica dopo le modifiche

Dopo aver completato le quattro remediation principali e la quinta prova facoltativa, ho eseguito nuovamente una Basic Network Scan sullo stesso target 192.168.51.101. La configurazione di rete è rimasta invariata, con il traffico tra Kali/Nessus e Metasploitable instradato tramite pfSense.

La scansione finale mostra 81 finding raggruppati, rispetto agli 86 della scansione iniziale. I cinque finding sui quali ho lavorato non compaiono più nel risultato finale. Rimangono naturalmente altre vulnerabilità Critical, High e di severità inferiore, perché Metasploitable contiene numerosi servizi volutamente vulnerabili che non rientravano nel perimetro di questa esercitazione.

Figura 1 - Risultato della Basic Network Scan finale dopo le remediation

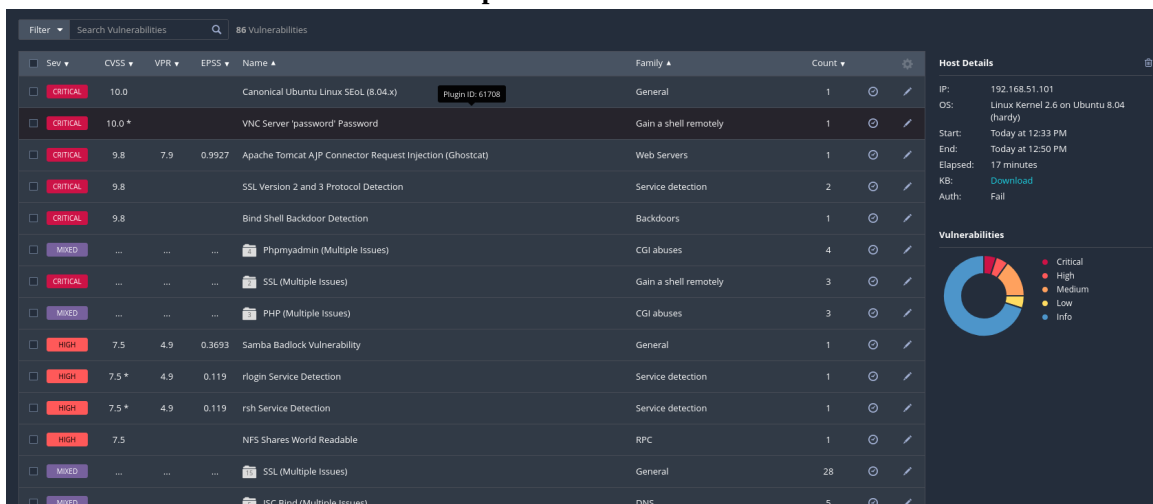


2. Confronto prima e dopo

Finding selezionato	Situazione iniziale	Risultato finale
NFS Exported Share Information Disclosure	Export NFS della root accessibile; finding presente	Finding non più presente
rexecd Service Detection	Servizio rexecd esposto su 512/TCP; finding presente	Finding non più presente
VNC Server 'password' Password	Nessus riusciva ad autenticarsi con “password”	Finding non più presente
Bind Shell Backdoor Detection	Shell root accessibile su 1524/TCP; finding presente	Finding non più presente
rlogin Service Detection (facoltativa)	513/TCP raggiungibile da Kali; finding presente	Finding non più presente dal punto di scansione

Nel caso di rlogin il risultato deriva da una mitigazione tramite firewall: il servizio continua a esistere sul target, ma pfSense blocca il traffico proveniente dalla macchina Kali verso la porta 513/TCP. Per questo il finding non è più rilevabile dal punto di scansione utilizzato.

Figura 2 - Estratto della scansione iniziale usato per il confronto



3. Conclusioni

Il confronto tra la scansione iniziale e quella finale conferma l'efficacia delle azioni eseguite. Per la bind shell e rexecd ho rimosso l'esposizione dei servizi tramite xinetd; per VNC ho sostituito la credenziale debole senza disabilitare il servizio; per NFS ho eliminato l'export della root; infine, per la prova facoltativa, ho utilizzato pfSense per filtrare rlogin. Le verifiche manuali con Nmap, Netcat, showmount e vncviewer sono risultate coerenti con la successiva scansione Nessus.

Le prove sono state svolte esclusivamente sulle macchine virtuali del laboratorio e hanno finalità didattica.

Nota finale: le vulnerabilità residue mostrate da Nessus non rientravano nel perimetro dell'esercitazione, che richiedeva la remediation di un numero selezionato di vulnerabilità Critical, con la possibilità di aggiungere una quinta prova facoltativa.